TRUST-AWARE AGENTIC AI FOR AUTONOMOUS CYBER INCIDENT RESPONSE AND RESILIENT RECOVERY

1. Problem Statement

Traditional cybersecurity solutions primarily emphasize attack prevention and detection. Sophisticated attacks, including ransomware and AI-assisted attacks, can bypass preventive controls and compromise multiple systems before they are fully understood. Once an attack occurs, organizations must rapidly determine which assets, evidence, identities, services and recovery points remain trustworthy; contain the compromise; restore critical services; and resume business operations. Existing incident-response and SOAR processes still rely substantially on manual investigation, static playbooks and operator decisions, which can increase Mean Time to Respond (MTTR) and delay recovery. This project proposes a trust-aware agentic AI cyber-resilience framework that autonomously correlates security telemetry and threat intelligence, assesses the trustworthiness of affected assets and recovery points, determines incident severity and blast radius, generates constrained response and recovery plans, and executes approved actions through secure orchestration. The framework prioritizes restoration according to business criticality and service dependencies while retaining human approval for high-risk actions and continuously validating the post-recovery state.

2. Abstract

This research proposes a Trust-Aware Agentic AI framework for autonomous cyber incident response and resilient recovery. Unlike conventional detection systems and static SOAR playbooks, the framework treats post-compromise trust assessment as a first-class decision problem. It correlates security telemetry and cyber-threat intelligence, constructs an incident and dependency graph, estimates the trustworthiness of affected assets, evidence sources and recovery points, and uses these trust states to constrain agentic response and recovery planning. A proposed Trust-Conditioned Recovery Planning mechanism assigns a normalized Recovery Trust Score to candidate recovery points using integrity, temporal validity, threat-free confidence, forensic evidence and reinfection risk. A policy-controlled execution layer enables safe automation while retaining human approval for high-impact actions. The framework will be evaluated in controlled ransomware and multi-stage attack scenarios against manual response, static playbooks and LLM-only agents using MTTR, service recovery time, recovery-point selection accuracy, contaminated-recovery rate, unsafe-action rate and residual compromise as primary metrics.

3. Research Gap (Research Papers are attached in GOOGLE DRIVE)

1. No explicit post-compromise recovery-trust layer: Recent autonomous-defense research demonstrates AI agents for cyber defense, but the proposed problem is more specific: determining what evidence, assets and recovery points remain trustworthy after compromise.

2. Recovery-point trust is not the central decision variable: A technically available backup is not necessarily safe. The proposed work makes recovery-point trust an explicit input and constraint.

3. Trust must be dynamic: Trust should change when new telemetry, forensic evidence, CTI or compromise-time estimates arrive.

4. Autonomous planning needs a trust constraint: An LLM may generate a plausible action, but plausibility is not authorization. The policy layer must block actions that violate trust or security constraints.

5. Recovery must consider business dependencies: The system must restore services in a safe dependency order, not merely restore the newest backup.

6. Evaluation must measure recovery safety: MTTR alone is insufficient. The project adds contaminated-recovery rate, recovery-point selection accuracy, unsafe-action rate and residual compromise.

4. Core Novel Idea: Trust-Conditioned Recovery Planning (TCRP)

The novelty should not be stated as simply combining LLMs, SOAR, threat intelligence and recovery. The proposed research contribution is a decision mechanism: TCRP dynamically evaluates the trustworthiness of candidate recovery points and affected assets, excludes unsafe recovery options, and generates a business- and dependency-aware recovery plan that is executed only after policy validation.

- Input: security telemetry + CTI + compromise timeline + asset/service graph + backup metadata + integrity/provenance evidence.
- Output: trust state for assets/evidence/recovery points + ranked response/recovery plan.
- Safety property: an action cannot execute if its target or recovery source violates a trust or policy constraint.
- Primary research question: can trust-conditioned planning reduce contaminated recovery and unsafe autonomous actions while also reducing MTTR?

5. Recovery Trust Score — Analysis

Baselin formula:

$$RTS = w_1 I + w_2 B + w_3 T + w_4 F - w_5 R$$

- I = Backup Integrity
- B = Backup Age / Freshness
- T = Threat-free confidence
- F = Forensic evidence confidence
- R = Risk of reinfection
- $w_1 \ldots w_5$ = weights

The intended output is RTS $\in [0,1]$.

6. Main Flaws in the Baseline Formula

The [0,1] range is not automatic. Because the equation contains a subtraction term, the score can become negative or exceed 1 unless inputs and weights are explicitly constrained.

Freshness is not the same as safety. A newer backup can have been created after ransomware compromise. Temporal validity relative to the estimated compromise window is more meaningful than age alone.

Linear addition may hide dangerous interactions. High integrity should not compensate for strong evidence that the backup was created after compromise. Some factors need to behave as gates or penalties.

Weights are currently arbitrary. The project must define how weights are initialized, calibrated and tested. Sensitivity and ablation experiments are required.

Variables need operational definitions. Each score must be derived from observable evidence such as hashes, timestamps, IOC scans, provenance and forensic corroboration.

Trust is currently static. The score must be recomputed when new evidence changes the compromise timeline or recovery assessment.

Evidence itself can be compromised. The framework must consider source provenance and independence; otherwise a compromised telemetry source can artificially increase trust.

No uncertainty is represented. A medium score can mean either moderate trust or insufficient evidence. The system should distinguish TRUSTED, UNCERTAIN and UNTRUSTED states.

No dependency context is included. A recovery point may be safe while its target or required dependency is compromised. Recovery trust must be evaluated in context.

7. Improved Formula (Recovery Trust Score) - RTS

$$\mathbf{BaseTrust = w_1 I + w_2 V + w_3 T + w_4 F}$$

$$\mathbf{RTS = BaseTrust \times (1 - R)}$$

- $I \in [0,1]$ = integrity confidence
- $V \in [0,1]$ = temporal validity / pre-compromise confidence
- $T \in [0,1]$ = threat-free confidence
- $F \in [0,1]$ = forensic/provenance confidence
- $R \in [0,1]$ = reinfection/compromise risk
- $w_i \geq 0$ and $w_1+w_2+w_3+w_4 = 1$

With these constraints, BaseTrust and RTS are in [0,1]. The multiplicative risk gate is deliberate: high reinfection risk should reduce usable trust instead of being treated as just another independent additive feature.

8. Calculating Each Variable

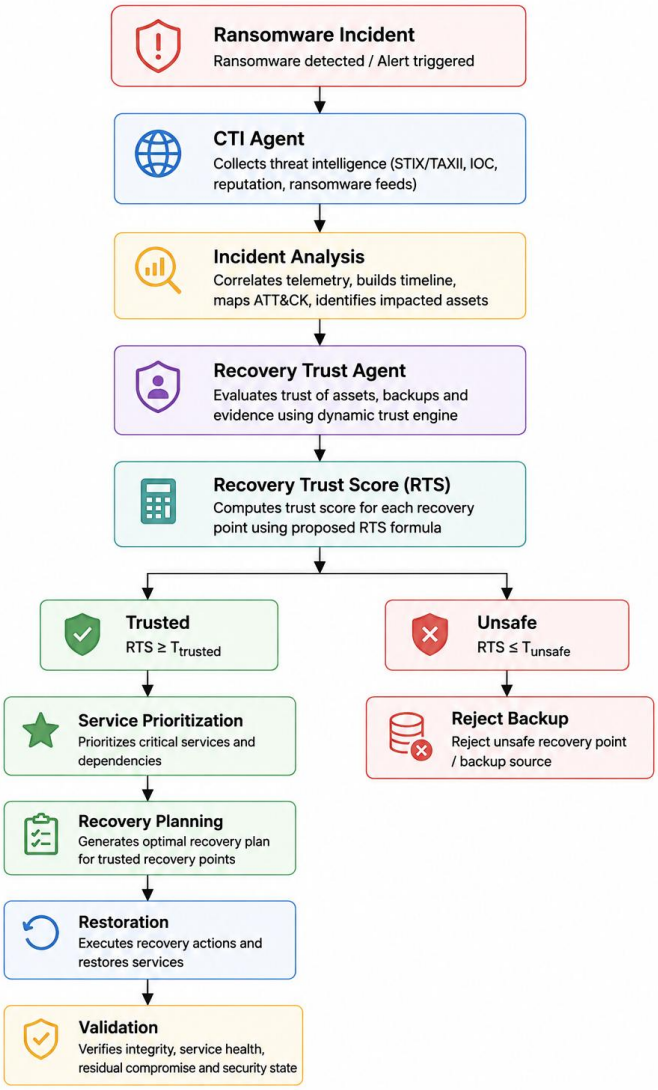
Variable	Evidence	Example
I — Integrity	hashes, signatures, filesystem consistency, restore verification	Verified hash + successful restore test → high I
V — Temporal validity	backup time vs estimated compromise start	Backup predates compromise → high V
T — Threat-free confidence	IOC scan, malware scan, threat intelligence, encryption indicators	No malicious indicators → high T
F — Forensic/provenance confidence	independent logs, chain of custody, trusted backup host	Independent evidence corroborates state → high F
R — Reinfection risk	backup-server compromise, malicious files, exposed credentials, compromised dependencies	Backup server compromised → high R

9. Trust States and Policy

Condition	State	Action
RTS ≥ τ_high and no hard violation	TRUSTED	Eligible for autonomous use where policy permits
τ_low ≤ RTS < τ_high or evidence incomplete	UNCERTAIN	Additional validation / human approval
RTS < τ_low or hard security violation	UNTRUSTED	Exclude from recovery

Hard rejection rules should override the numeric score—for example, confirmed malware in a recovery image or a known-compromised backup host should reject that recovery point regardless of RTS.

10. Proposed Framework



11.Agent Roles

Agent	Responsibility	Output
Triage Agent	Incident classification and severity	Type, severity, confidence
Investigation Agent	Evidence correlation and attack-chain reconstruction	Timeline, affected assets, hypotheses
Trust Agent	RTS calculation and trust assessment	Score, state, reasons
Response Planner	Containment selection	Ranked response plan
Recovery Planner	Recovery-point selection and restoration order	Recovery plan / dependency DAG
Execution Agent	Approved action execution	Action results
Validation Agent	Post-recovery safety validation	Pass/fail, residual-risk score

12. Recovery Planning

Recovery is a constrained planning problem, not simply "restore the newest backup."

Minimize α·SecurityRisk + β·BusinessDowntime + γ·RecoveryCost + δ·ResidualRisk

Subject to: RTS(recovery point) ≥ τ; mandatory dependencies are restored first; high-impact actions require approval; and no action exceeds the permitted blast radius.

13. Summary

Item	Final choice
Title	Trust-Aware Agentic AI for Autonomous Cyber Incident Response and Resilient Recovery
Main gap	No explicit trust-conditioned post-compromise recovery mechanism that evaluates recovery points/evidence and constrains autonomous recovery.
Core novelty	Trust-Conditioned Recovery Planning (TCRP).
Formula	BaseTrust = $w_1 I + w_2 V + w_3 T + w_4 F$; RTS = BaseTrust × (1−R).
Main experiment	Clean vs. compromised recovery-point selection under ransomware.
Main metrics	MTTR, recovery-point selection accuracy, contaminated-recovery rate, unsafe-action rate, residual compromise, service recovery time.
Main baselines	Manual, static SOAR, LLM-only, additive RTS, proposed TCRP.
Safety	Deterministic policy gate + human approval for high-impact actions + post-recovery validation.